정보보안기사 실기 21회 — 문제와 답안

원본: newbt.kr 복원 기출 (2.pdf). 답안은 복원 문항 기준의 모범 답안이며 공식 정답이 아니다.

단답형

1. Sendmail에서 스팸메일 릴레이 제한 설정 후 access db를 생성하려고 한다. ( )안에 들어갈 명령어를 기술하시오.

```
# (A) (B) etc/mail/access.db < etc/mail/access
```

답안

A `makemap` · B `hash`

완성된 명령은 `makemap hash /etc/mail/access.db < /etc/mail/access` 이다.

2. 라우터에서 snmp 프로토콜을 비활성화 하려고 한다. ( )에 들어갈 명령어를 기술하시오.

```
Router# configure terminal
Router(config)# ( A ) ( B )
```

답안

A `no` · B `snmp-server`

3. 위험분석 관련하여 다음 물음에 답하시오.

1) 위험을 모두 제거하는 것은 현실적으로 불가능하므로, 수용가능한 수준으로 경감시키기 위한 보호대책을 마련하는 것이 중요하다. 이 경우, 수용가능한 수준의 위험을 지칭하는 용어를 기술하시오.
2) 위험이 낮으면 원칙적으로 비용절감을 위해 그냥 두는 것이 맞는지 O/X로 답하시오.

답안

1) 목표 위험 수준, **DoA**(Degree of Assurance)

복원 답안에 따라 잔여 위험(Residual Risk)으로 적기도 한다. 잔여 위험은 대책 적용 뒤 남은 위험이고, DoA는 그 위험이 넘지 말아야 할 수용 가능 수준이다.

2) O

위험이 DoA 이하이면 대책 비용이 기대 손실보다 크므로 수용한다. 다만 경영진 승인을 받고 계속 모니터링한다.

4. 업무 연속성 계획(BCP) 5단계 중 2~4단계의 명칭을 기술하시오.

답안

2단계 사업영향평가(BIA) · **3단계** 복구 전략 개발 · **4단계** 복구 계획 수립

전체 순서는 프로젝트 범위 설정 및 기획 → 사업영향평가 → 복구 전략 개발 → 복구 계획 수립 → 테스트 및 유지보수다.

5. 특정 대상을 겨냥해 다양한 공격 기법(특히 알려지지 않은 취약점을 이용)을 동원하여 장기간 지속적으로 공격하는 기법을 무엇이라고 하나?

답안

APT(Advanced Persistent Threat, 지능형 지속 위협)

6. 불완전한 암호화 저장 취약점이 있는 웹 애플리케이션은 데이터와 자격 증명을 적절히 보호하기 위한 암호화 기능을 거의 사용하지 않아서, 보호되지 않은 데이터를 이용하여 신원 도용이나 신용카드 사기와 같은 범죄가 이루어질 수 있다. 해당 취약점을 점검하는 방법에 대하여 ( ) 에 들어갈 용어를 설명하시오.

1) DB에 저장된 중요정보가 (A)로 열람가능한지 확인한다.
2) (B) 또는 암호화된 쿠키값이 명백하게 랜덤으로 생성되는지 확인한다.
3) 적절한 (C)이 제대로 적용되었는지 검증한다.

답안

A 평문 · **B** 세션 ID(세션 토큰) · **C** 암호화 알고리즘(안전한 표준 알고리즘과 키 관리)

7. TCP/IP의 인터넷계층에서 동작하는 프로토콜에 대하여 ( )에 들어갈 용어를 기술하시오.

1) (A) : 인터넷 계층에서 동작하는 대표적인 VPN 프로토콜
2) (B) : (A)의 세부 프로토콜로 무결성 보장, 메시지 인증 가능
3) (C) : (A)의 세부 프로토콜로 암호화를 통한 기밀성 유지 가능

답안

A IPSec · **B** AH(Authentication Header) · **C** ESP(Encapsulating Security Payload)

8. 위험분석 방법과 관련하여 ( ) 안에 들어갈 명칭을 기술하시오.

(A) : 시스템에 관한 전문적인 지식을 가진 전문가의 집단을 구성하고 위험을 분석 및 평가하여 정보시스템이 직면한 다양한 위험과 취약성을 토론을 통해 분석하는 방법
(B) : 어떤 사건도 기대대로 발생하지 않는다는 사실에 근거하여 일정 조건하에서 위험에 대한 발생가능한 결과들을 추정하는 방법
(C) : 자산, 위협, 보안체계등 위험분석 요인들을 정성적 언어로 표현된 값을 사용하여 기대손실을 평가하는 방법

답안

A 델파이법 · **B** 시나리오법 · **C** 퍼지 행렬법

9. 익스플로잇 코드와 관련되어 ( )에 들어갈 용어를 기술하시오.

(A) : 어셈블리어/기계어로 구성되어 있는 익스플로잇 코드의 본체에 해당하는 프로그램
(B) : NOP(No Operation)에 해당하는 x86 Hex Code
(C) : ESP(Extended Stack Pointer) 레지스터에 있는 값을 EIP(Extended Instruction Pointer) 레지스터로 옮기는 어셈블리 명령

답안

A 셸코드(Shellcode) · B `0x90` · C `JMP ESP`

10. httpd.conf 파일에서 디렉토리에 업로드 가능한 최대파일사이즈를 제한하는 명령어는?

답안

`LimitRequestBody`

예: `<Directory /var/www/upload> LimitRequestBody 5000000 </Directory>` 는 약 5MB로 제한한다.

서술형

11. IDS에서 사용하는 침입탐지 방식에 대하여 다음 물음에 답하시오.

1) 오용 탐지의 정의
2) 이상 탐지의 정의
3) 오용 탐지의 장점
4) 오용 탐지의 단점

답안

1) 오용 탐지: 알려진 공격 패턴을 시그니처로 저장해 두고, 이와 일치하는 행위를 침입으로 탐지한다(지식 기반).
2) 이상 탐지: 정상 행위의 통계적 프로파일을 만들고, 여기서 크게 벗어나는 행위를 침입으로 탐지한다(행위 기반).
3) 장점: 오탐(False Positive)이 적고 탐지가 빠르다. 어떤 공격인지 명확히 알 수 있다.
4) 단점: 시그니처가 없는 새로운 공격이나 변형 공격(제로데이)은 탐지하지 못한다. 시그니처를 계속 갱신해야 한다.

12. 재해복구시스템 유형에는 미러사이트, 핫사이트, 웜사이트, 콜드사이트가 있다. 다음 물음에 답하시오.

1) 미러 사이트의 정의
2) 미러사이트의 장단점 각 2개씩 설명
3) RTO가 가장 오래 걸리는 방식은 무엇이며, 이유는 무엇인가?

답안

1) 정의: 주 센터와 같은 수준의 IT 자원을 원격지에 구축하고, 두 센터가 실시간으로 동시에 서비스하는(Active-Active) 방식이다.
2) 장점: 재해 시 즉시 전환되어 RTO가 0에 가깝다. 실시간 동기화로 데이터 손실(RPO)이 거의 없다.
단점: 구축과 유지 비용이 가장 높다. 데이터 갱신이 잦은 시스템은 실시간 동기화 부하가 커서 적용이 어렵다.
3) 콜드 사이트: 장소와 전원·통신 같은 기본 설비만 갖춰 두고, 장비와 데이터는 재해가 난 뒤에 들여와 구축하므로 복구에 수 주에서 수 개월이 걸린다.

13. 개인정보의 기술적, 관리적 보호조치 기준에 포함된 개인정보취급자의 비밀번호 작성규칙 3가지를 기술하시오.

답안

1. 영문 대문자·소문자·숫자·특수문자 중 2종류 이상을 조합하면 최소 10자리 이상, 3종류 이상을 조합하면 최소 8자리 이상으로 구성한다.
2. 연속적인 숫자나 생일, 전화번호처럼 추측하기 쉬운 개인정보와 아이디와 비슷한 비밀번호는 쓰지 않는다.
3. 비밀번호에 유효기간을 두어 반기별 1회 이상 변경한다.

실무형

14. 동일한 출발지 IP에서 2초동안 80번 포트로 30개 이상 SYN요청이 들어오는 경우 차단하는 IPtables 룰을 작성 하시오. (룰 옵션을 5개로 구분하여 설명하시오)

답안

```
iptables -A INPUT -p tcp --dport 80 --syn -m recent --set
iptables -A INPUT -p tcp --dport 80 --syn -m recent --update --seconds 2 --hitcount 30 -j DROP
```

1. `-A INPUT` : 들어오는 패킷 체인(INPUT)에 규칙을 추가한다.
2. `-p tcp --dport 80` : 목적지 포트가 80인 TCP 패킷을 대상으로 한다.
3. `--syn` : SYN 플래그만 켜진 연결 요청 패킷만 고른다.
4. `-m recent --update --seconds 2 --hitcount 30` : 같은 출발지 IP에서 2초 동안 30번 이상 들어왔는지 센다. 첫 줄의 `--set`이 출발지 IP를 목록에 기록한다.
5. `-j DROP` : 조건에 맞는 패킷을 버린다.

recent 모듈은 IP마다 기본 20개까지만 기억하므로, 실제 운영에서는 모듈 옵션 `ip_pkt_list_tot`를 30 이상으로 올려야 한다.

15. 정량적 위험평가 방법인 ALE와 관련하여 다음 물음에 답하시오.

1) SLE의 정의
2) SLE 계산 공식
3) ALE 계산을 위해 필요한 정보는 무엇인가?
4) 연간 손실이 완전 제거되는데 투입된 비용이 X라 할 때, 문제에서 언급된 변수만으로 ROI(%)를 구하는 계산식은?

답안

1) SLE(단일 예상 손실액)는 위협이 한 번 발생했을 때 예상되는 손실 금액이다.

2) `SLE = AV(자산 가치) × EF(노출 계수)`

3) SLE와 ARO(연간 발생률)가 필요하다. `ALE = SLE × ARO`

4) `ROI(%) = (ALE − X) / X × 100`

대책으로 줄어든 연간 손실이 ALE 전부이므로, 그 이익에서 비용 X를 뺀 값을 X로 나눈다.

16. MASTER와 SLAVE DNS 서버의 존파일 설정과 관련하여 다음 물음에 답하시오.

```
Master name 서버 : ns1.korea.go.kr (192.168.1.1)
Slave name 서버 : ns2.korea.go.kr (192.168.1.2)

1) Master DNS 서버의 zone 파일 설정을 위하여 다음 ( )에 들어갈 설정 값을 쓰시오.

/etc/named.conf
zone "korea.go.kr" IN {
      type ( A );
      file "korea.go.kr.db";
      allow-update { ( B ) };
};

/var/named/korea.go.kr.db
$TTL 1000
@  IN SOA ns1.korea.go.kr master.korea.go.kr. (
                 2022113001 ; serial
                 21600 ; refresh
                 3600 ; retry
                 604800 ; expire
                 3600 ) ; minimum
     IN NS ns1.korea.go.kr.
     IN NS ns2.korea.go.kr.
ns1  IN A ( C )
ns2  IN A ( D )

2) Slave DNS 서버의 zone 파일 설정을 위하여, 다음 ( )에 들어갈 설정값을 쓰시오.

/etc/named.conf
zone "korea.go.kr" IN {
      type ( E );
      file "slave/korea.go.kr.db";
      masters { ( F ) };
};
```

답안

A `master` · **B** `none;` · **C** `192.168.1.1` · **D** `192.168.1.2` · **E** `slave` · **F** `192.168.1.1;`

allow-update는 동적 업데이트를 허용할 호스트이며, 보안상 none으로 막는다.